

CÓMO CONVERTIRSE EN ANALISTA DE GRC

Guía práctica de gobierno, riesgo, cumplimiento, auditoría y preparacion profesional

Alberto (Al) Leiva

Versión 1.0 - Julio de 2026

CC BY-NC-SA 4.0

Tabla de contenido

- Propósito y uso responsable
- 1. Qué hace un analista de GRC
- 2. Niveles profesionales y desarrollo
- 3. Conocimientos esenciales
- 4. Marcos y normás
- 5. Método de evaluación de riesgos
- 6. Controles y pruebas
- 7. Recopilación de evidencia
- 8. Políticas y procedimientos
- 9. Preparación para auditorías
- 10. Riesgo de terceros
- 11. Gobierno de nube e IA
- 12. Herramientas
- 13. Comunicación
- 14. Proyectos de portafolio
- 15. Currículum y entrevistas
- 16. Plan de 30, 60 y 90 días
- 17. Practical templates / Plantillas prácticas
- 18. Official references / Referencias oficiales

Propósito y uso responsable

Este manual ayuda a principiantes y personas que desean cambiar de carrera a comprender el trabajo de un analista de Gobierno, Riesgo y Cumplimiento, y a crear evidencia práctica y ética para su portafolio. No sustituye asesoría legal, capacitación de certificación ni políticas específicas de una organización.

Utilice solamente información ficticia, anonimizada o autorizada en ejercicios y portafolios. Nunca publique datos confidenciales, información personal, credenciales, evidencia de auditoría o registros regulados.

1. Qué hace un analista de GRC

Un analista de GRC conecta objetivos empresariales, tecnología, riesgo, controles, evidencia y responsabilidad. El trabajo no consiste solamente en completar listas. Es necesario comprender por qué existe un control, cómo reduce el riesgo, si funciona y cómo comunicar brechas de manera profesional.

Las responsabilidades habituales incluyen evaluaciones de riesgo, mapeo de controles, revisión de evidencia, apoyo a políticas, coordinación de auditorías, seguimiento de hallazgos, riesgo de terceros, monitoreo de cumplimiento, métricas e informes ejecutivos.

2. Niveles profesionales y desarrollo

Los analistas iniciales suelen recopilar evidencia, mantener registros, apoyar evaluaciones, actualizar documentación y seguir remediaciones. Los niveles intermedios dirigen evaluaciones y pruebas. Los profesionales senior diseñan programas, asesoran a ejecutivos e integran el riesgo cibernético con el riesgo empresarial.

3. Conocimientos esenciales

Aprenda fundamentos de ciberseguridad, redes, nube, identidad, protección de datos, vulnerabilidades, respuesta a incidentes, continuidad, privacidad y auditoría. No necesita ser el especialista técnico más profundo, pero debe formular preguntas precisas y reconocer evidencia incompleta.

4. Marcos y normas

Comience con NIST CSF 2.0, ISO/IEC 27001, CIS Controls, conceptos de SOC 2, PCI DSS cuando existan datos de pago, HIPAA cuando corresponda, obligaciones de privacidad y NIST AI RMF para riesgos de IA. No afirme el cumplimiento sin comprender alcance, evidencia, excepciones y eficacia operativa.

5. Método de evaluación de riesgos

Una evaluación práctica identifica activos, amenazas, vulnerabilidades, controles existentes, probabilidad, impacto, propietario, tratamiento, fecha y riesgo residual. Use una escala coherente y explique sus supuestos.

Campo	Ejemplo
Riesgo	Acceso no autorizado a datos de clientes
Activo	Base de datos de clientes
Amenaza	Cuenta comprometida
Debilidad	Sin MFA resistente a phishing
Probabilidad	Posible
Impacto	Alto
Tratamiento	Implementar MFA reforzada y monitoreo
Propietario	Responsable de identidad
Riesgo residual	Medio después de validar

6. Controles y pruebas

Un control debe tener objetivo, propietario, frecuencia, procedimiento, evidencia, poblacion y proceso de excepciones. La eficacia del diseño pregunta si el control podría reducir el riesgo. La eficacia operativa pregunta si realmente funcionó durante el período revisado.

Elemento	Pregunta
Objetivo	Qué riesgo reduce?
Propietario	Quién responde?
Frecuencia	Con qué frecuencia?
Evidencia	Qué demuestra operacion?
Poblacion	Qué sistemás o usuarios cubre?
Excepcion	Cómo se registran fallas?

7. Recopilación de evidencia

La evidencia debe ser pertinente, confiable, completa, atribuible, protegida y correspondiente al período. Ejemplos: políticas aprobadas, exportaciones de configuración, revisiones de acceso, tickets, capturas con contexto, registros de capacitación, logs, aprobaciones y reportes.

8. Políticas y procedimientos

Las políticas expresan expectativas de la dirección. Los estándares establecen requisitos obligatorios. Los procedimientos explican cómo se realiza el trabajo. Las guías recomiendan prácticas. Asigne propietarios y ciclos de revisión.

9. Preparación para auditorías

Mantenga una lista de solicitudes, propietario, fecha, estado, revisor, excepcion y resultado. Prepare evidencia con anticipación, pero nunca fabrique ni antedate registros. Sea transparente y documente acciones correctivas.

10. Riesgo de terceros

Evalúe el servicio, los datos, la conectividad, la criticidad, la ubicación, los subcontratistas, la resiliencia, las obligaciones de incidentes y las protecciones contractuales. Un cuestionario no es suficiente para proveedores de alto riesgo.

11. Gobierno de nube e IA

En nube, comprenda responsabilidad compartida, identidades, registros, cifrado, exposición de red, copias de seguridad y configuración. Para IA, mantenga inventario, propósito, clasificación, nivel de riesgo, supervisión humana, evaluaciones, proveedores, monitoreo e incidentes.

12. Herramientas

Las herramientas pueden incluir hojas de cálculo, tickets, plataformas GRC, repositorios, escáneres, reportes SIEM, paneles de nube, Microsoft Purview, Defender for Cloud, Vanta, Drata, ServiceNow GRC, Archer, OneTrust y herramientas de código abierto. Aprenda primero el proceso.

13. Comunicación

Redacte hallazgos con condición, criterio, causa, riesgo, recomendación, propietario y fecha. Separe hechos de supuestos. Use lenguaje respetuoso y explique a los ejecutivos el impacto y las decisiones necesarias.

14. Proyectos de portafolio

Cree ejemplos anonimizados: registro de riesgos, matriz de controles, politica, evaluación de proveedor, seguimiento de auditoría, informe de ejercicio, revisión de nube, inventario de IA y panel ejecutivo. Incluya un README con propósito, alcance, supuestos y limites eticos.

- Risk register / Registro de riesgos
- Control matrix / Matriz de controles
- Evidence request tracker / Seguimiento de evidencia
- Third-party assessment / Evaluación de terceros
- Executive risk summary / Resumen ejecutivo

15. Currículum y entrevistas

Muestre resultados, alcance, marcos, evidencia y colaboración. No invente auditorías, certificaciones ni experiencia regulada. Prepare ejemplos con Situación, Tarea, Acción y Resultado.

16. Plan de 30, 60 y 90 días

Días 1-30: aprender riesgo, controles, evidencia, NIST CSF 2.0 y fundamentos. Días 31-60: crear artefactos y practicar pruebas. Días 61-90: realizar una evaluación ficticia completa, mejorar comunicación y solicitar empleos.

17. Practical templates / Plantillas prácticas

Ejemplo de hallazgo

Condición: No se completaron las revisiones trimestrales de acceso para dos aplicaciones de producción. Criterio: El estándar exige revisión trimestral. Riesgo: Podría permanecer acceso inapropiado. Recomendación: Completar la revisión, retirar acceso innecesario, identificar la causa y monitorear el cumplimiento futuro. Propietario y fecha: Asignados por la dirección.

Campos para el seguimiento de evidencia

- ID de solicitud
- Control
- Evidencia solicitada
- Propietario
- Fecha
- Estado
- Revisor
- Excepción
- Conclusión final

Seguridad humana y ética profesional

Nunca humille a una persona por una falla de control. Concentre el trabajo en sistemas, decisiones, evidencia, riesgo y mejora. Proteja la información personal y la evidencia confidencial.

18. Official references / Referencias oficiales

[NIST Cybersecurity Framework 2.0](#)

[NIST CSF 2.0 publication](#)

[NIST AI Risk Management Framework](#)

[ISO/IEC 27001 overview](#)

[PCI DSS v4.0.1](#)

[CIS Critical Security Controls](#)

[OWASP Foundation](#)

License / Licencia

Copyright © 2026 Alberto (Al) Leiva. CC BY-NC-SA 4.0.